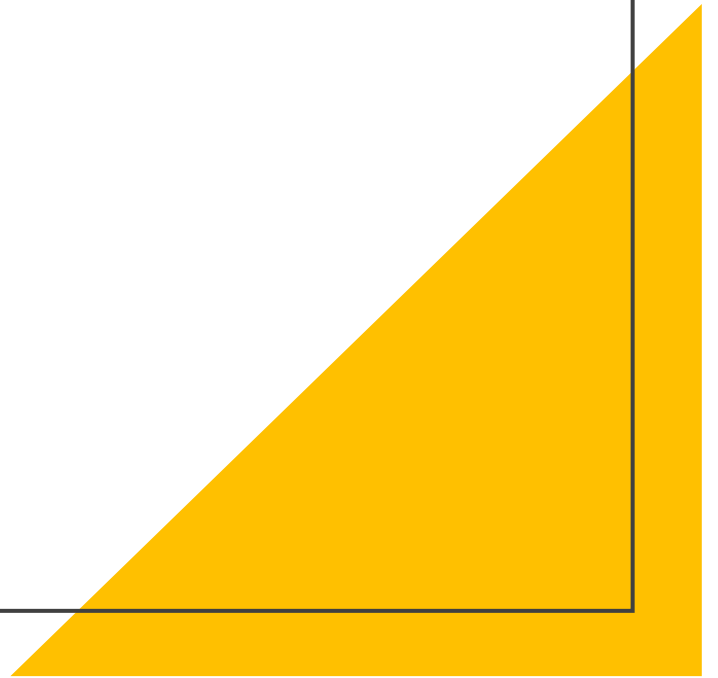


Sociotechnical Security

CS 8803/4803

Professor Veronica Rivera

Lecture 10 – Privacy (policy notices)



Last time

- Specific security warning design problems
 - E.g., Where to place warnings in email phishing notifications?
- More recent applications of early security warning research
 - Mis/disinformation warnings
 - AI content warnings
 - Social media warning labels for kids

Today

- Privacy policies & notices
 - Akshat will lead a discussion on the measuring GDPR compliance
- Background on privacy policies
- Human-centered research on privacy notices
- Recent research developments on these topics

What Is Privacy Notice And Choice (Consent)?

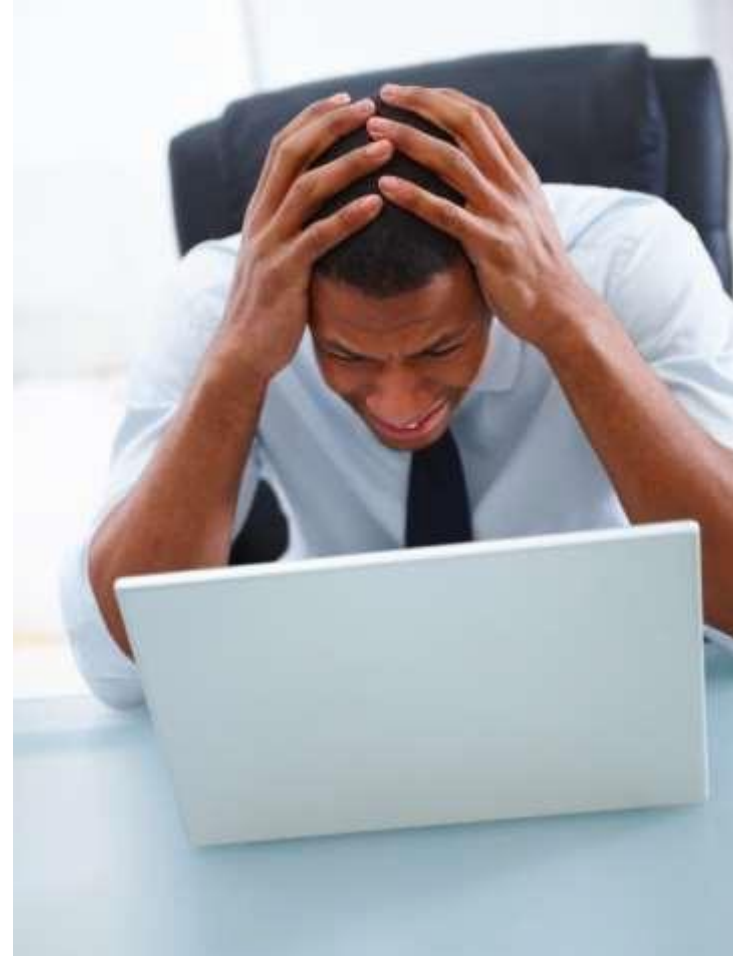
Notice: Providing information about the privacy and data practices, similar to the content of privacy policy and user agreement.

Choice: The action signifying the user's acceptance of the terms provided in the notice. Either by clicking on a choice button or by staying on the platform.

Nobody wants to read privacy policies

“the notice-and-choice model, as implemented, has led to long, incomprehensible privacy policies that consumers typically do not read, let alone understand”

- *Protecting Consumer Privacy in an Era of Rapid Change*. Preliminary FTC Staff Report. December 2010.



Cost of reading privacy policies

- What would happen if everyone read the privacy policy for each site they visited once per year?
- Time = 244/hours year
- Cost = \$3,534/year
- National opportunity cost for time to read policies: \$781 billion



A. McDonald and L. Cranor. [The Cost of Reading Privacy Policies](#). I/S: A Journal of Law and Policy for the Information Society. 2008 Privacy Year in Review Issue.

The State Of Notice And Choice In US And Abroad

- Notice is **mainly optional in the US**, though it is **enforceable** by the **FTC** and the **State Attorneys General**.
- **Some states** have **privacy laws** requiring businesses to provide users with notice and consent. Examples include California (CCPA), Virginia (VCDPA), and Colorado (CPA).
 - Mostly opt-out choices for consent
 - Opt-in for sensitive data
- Notice and consent are required by a **few US sectors**, including HIPAA in Healthcare and COPPA in Children's Online Privacy.
- In the **EU**, under **GDPR**, notice and choice are mandatory.

EU General Data Protection Regulation (effective 2018)

- Big privacy law
 - General Data Protection Regulation
 - Replaces the Data Protection Directive
- 4 examples:
 - Right of access (Article 15)
 - Right to be forgotten (Article 17)
 - Right to data portability (Article 20)
 - Rights related to automated decision-making (Article 22)



GDPR also sets usability standards for notice and choice

- “have transparent and easily accessible policies”
- “provide any information... in an intelligible form, using clear and plain language, adapted to the data subject”
- Request consent in a way that is “clear, concise, and not unnecessarily disruptive”

Simplified notice and choice

“the question is not whether consumers should be given a say over unexpected uses of their data; rather, **the question is how to provide simplified notice and choice.**”



Edith Ramirez Former FTC Chairwoman

January 2015

Speaking about IoT privacy

Towards a privacy “nutrition label”

- Standardized format
 - People learn where to find answers
 - Facilitates policy comparisons
- Standardized language
 - People learn terminology
- Brief
 - People find info quickly
- Linked to extended view
 - Get more details if needed



Iterative design process

- Series of studies
 - Focus groups
 - Lab studies
 - Online studies
- Metrics
 - Reading-comprehension (accuracy)
 - Time to find information
 - Ease of policy comparison
 - Subjective opinions, ease, fun, trust

P.G. Kelley, J. Bresee, L.F. Cranor, and R.W. Reeder. A “Nutrition Label” for Privacy. SOUPS 2009.

P.G. Kelley, L.J. Cesca, J. Bresee, and L.F. Cranor. Standardizing Privacy Notices: An Online Study of the Nutrition Label Approach. CHI 2010.

Acme						
information we collect	ways we use your information				information sharing	
	provide service and maintain site	marketing	telemarketing	profiling	other companies	public forums
contact information		opt out	opt out			
cookies						
demographic information		opt out	opt out			
financial information						
health information						
preferences		opt out	opt out			
purchasing information		opt out	opt out			
social security number & gov't ID						
your activity on this site		opt out	opt out			
your location						

Access to your information
This site gives you access to your contact data and some of its other data identified with you.

How to resolve privacy-related disputes with this site
Please email our customer service department

acme.com
5000 Forbes Avenue
Pittsburgh, PA 15213 United States
Phone: 800-555-5555
help@acme.com



we will collect and use your information in this way



by default, we will collect and use your information in this way unless you tell us not to by opting out



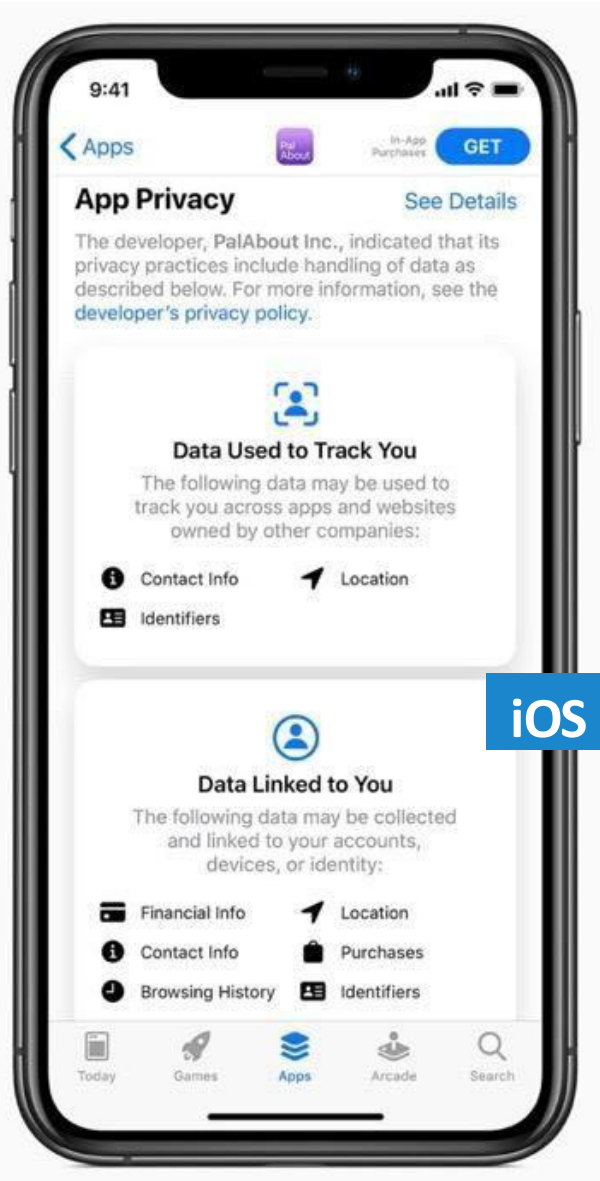
we will not collect and use your information in this way



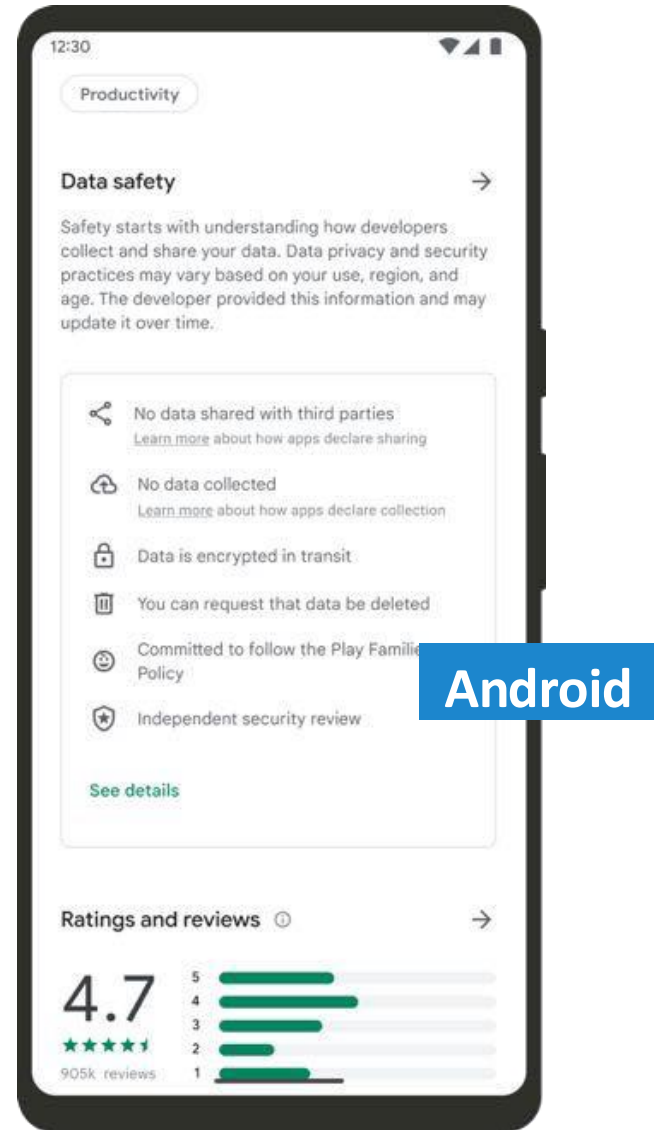
by default, we will not collect and use your information in this way unless you allow us to by opting in

Slide credit: Elissa Redmiles

Privacy nutrition labels in app stores



iOS



Android

- iOS privacy labels since December 2020
- Google Play data safety labels since April 2022
- But are they useful and usable?

Other human-centered & empirical research on privacy

- **User mental models of privacy**
 - How do people conceptualize privacy?
 - How do privacy mental models influence behavior?
 - How can new interfaces help users make better privacy tradeoffs?
- **Visualizing technical definitions of privacy**
 - How can we communicate privacy guarantees to users visually?
- **Measuring compliance with privacy policies**
 - Are websites compliant with privacy laws?
 - How can we automate these analyses?
 - Recent LLM approach: Qinge Xie et al., [Evaluating Privacy Policies under Modern Privacy Laws At Scale: An LLM-Based Automated Approach](#), USENIX Security 2025
- **HCI research on GDPR**
 - How do users interpret different clauses and articles in GDPR?
 - How to design better/more usable consent interfaces?
 - How does GDPR apply to AI systems?

User mental models of privacy

- Users constantly trade off privacy against utility and convenience
- Mental models shape what people share with an AI chatbot
 - What are their mental models?
 - How do these inform tradeoffs between privacy, utility, and convenience?
- Analysis of real-world ChatGPT conversations plus interviews with 19 users
 - Benefits are concrete; risks are abstract and hard to judge
- Wrong mental models and dark patterns hide the risks
 - Human-like interaction encourages even more sensitive disclosure
- Authors call for new design guidelines and a privacy paradigm shift

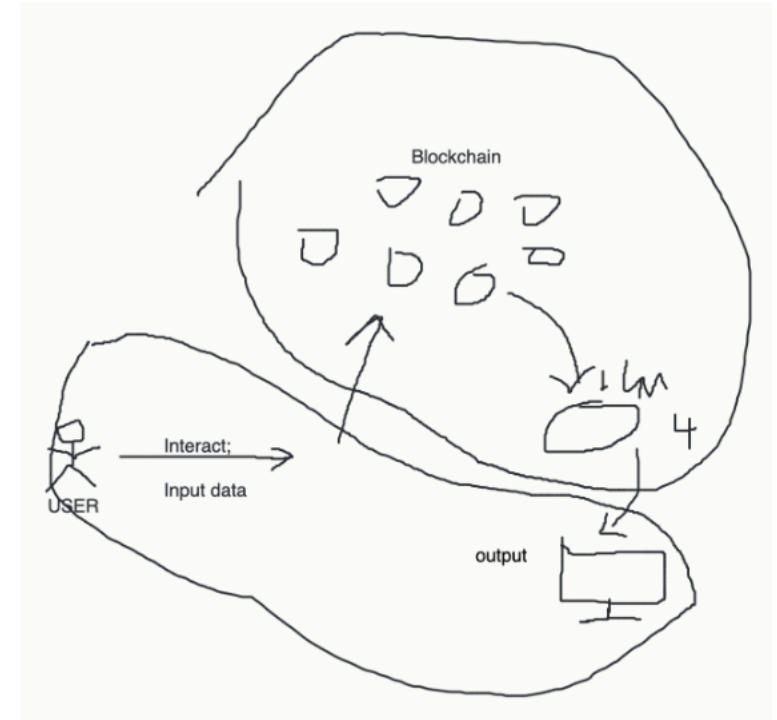
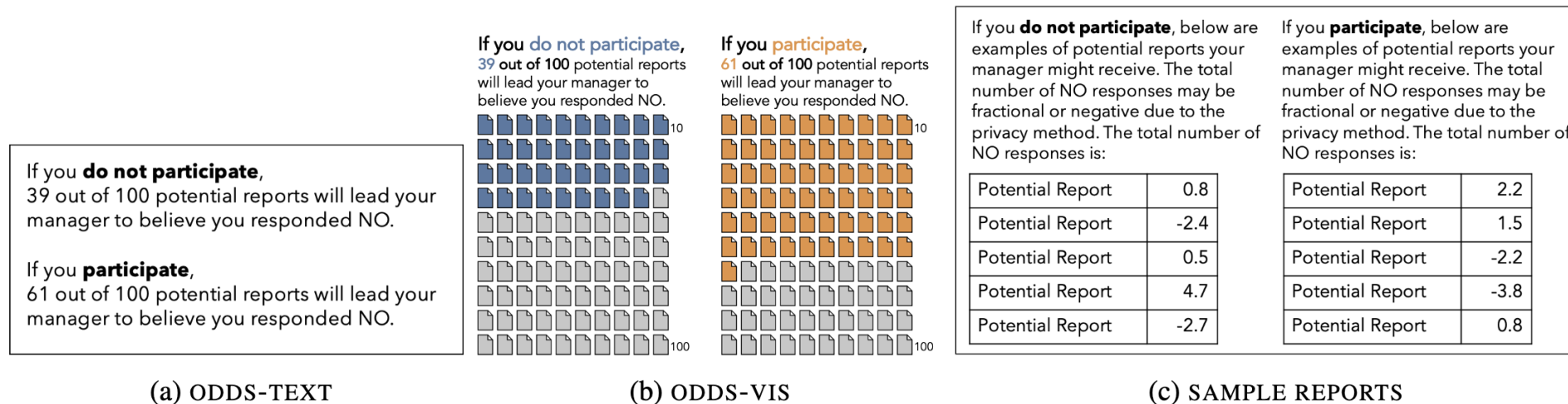


Figure 2: Screenshot of P8's drawing representing mental model A: ChatGPT is magic.

Zhang et al., [“It’s a Fair Game”, or Is It? Examining How Users Navigate Disclosure Risks and Benefits When Using LLM-Based Conversational Agents](#), CHI 2024.

Visualizing technical definitions of privacy

- Mathematicians define privacy in different ways that engineers implement and deploy
 - How do you communicate it to users?
- One example: Differential privacy (DP)
 - Setting: Does your data get included in an analysis?
 - Privacy ideal: no; real: yes
 - DP guarantees the two aren't "that" different, ergo inclusion is ok



Next time

Be prepared to share/give feedback on your projects from two other groups

- 20 minute rounds (~10 minutes per group)
- Each group discusses:
 - Problem they are trying to solve
 - How they propose solving that problem
 - Why that problem matters
 - What they are hoping to find
- Ask each other questions:
 - Would you believe my results if I did X?
 - What about my approach would make you skeptical of my results?
 - Have you thought about doing X?

Remainder of class will be a work session